

Celego Evidencias Seguras

Guía extensa para configurar el VPS Relay en Hostinger

Campo	Valor
Documento	Configuracion segura del Relay DMZ para evidencias de entrega
Version	1.0 - Fase 0 y Fase 1
Fecha	2026-06-20
Dominio de ejemplo	relay.celego.example
Estandar reverse proxy	Caddy con HTTPS automatico
Alcance	Entregable interno; no configura credenciales reales ni hPanel

Este documento es una guía operativa para TI. No contiene secretos, no sustituye aprobación BPD/legal y debe ajustarse con el dominio, IP administrativa, region y políticas contractuales reales.

Indice

- Resumen ejecutivo y criterios de exito.
- Arquitectura DMZ y frontera de datos.
- Alta del VPS en Hostinger hPanel.
- DNS, hostname y dominio del relay.
- SSH keys, usuario sudo y hardening base.
- Firewall Hostinger, UFW y Fail2ban.
- Docker Compose, Caddy y servicio relay.
- Despliegue desde Git, validacion y pruebas anti-PII.
- Backups, snapshots, monitoreo, rollback e incidentes.
- Anexos con comandos, checklists y fuentes.

La guia esta escrita para una primera salida controlada. Las secciones pueden convertirse en runbooks separados cuando el equipo de TI tenga el dominio real, IPs aprobadas y decision de region.

1. Resumen ejecutivo

Celego necesita recibir evidencias de entrega desde dispositivos moviles sin exponer fotos de cedula, acuses legibles, nombres, direcciones, telefonos o datos de tarjeta en un VPS publico. La solucion de Fase 1 usa un Relay DMZ en Hostinger que solo transporta blobs cifrados y metadata tecnica.

Resultado esperado

- El subdominio publico responde por HTTPS con certificado automatico.
- Caddy recibe trafico publico y reenvia internamente al relay.
- El relay no tiene puerto publico directo.
- El relay no posee base core, PII, llave privada maestra ni archivos del portal.
- El firewall Hostinger y UFW permiten solo 80/443 y SSH restringido.
- Los backups/snapshots existen, pero no extienden la retencion del relay.

Criterios de listo para piloto

Control	Debe cumplirse
DNS	A/AAAA del subdominio apunta al VPS
HTTPS	Caddy emite certificado valido y renueva automaticamente
Healthcheck	`https://<dominio>/health` responde `200`
Firewall	SSH solo desde IP aprobada; 80/443 publicos
Datos	Payload con PII se rechaza antes de persistir
Backups	Snapshot previo y prueba de restauracion documentada
Legal	Region y retencion aprobadas por BPD/legal

2. Arquitectura DMZ

La DMZ evita que el celular alcance la red interna. El VPS Relay queda expuesto solo para recibir paquetes cifrados. La llave privada que puede descifrar evidencias vive en el servidor fisico de Celego, nunca en Hostinger.

```
App movil corporativa
-> cifra evidencia con AES-256-GCM
-> envia blob cifrado + manifiesto tecnico

Internet
-> HTTPS publico

Caddy en VPS Hostinger
-> termina TLS
-> aplica limite de cuerpo y headers
-> proxy interno

Relay DMZ
-> valida contrato sin PII
-> valida hash y tamano
-> persiste solo metadata tecnica temporal

Servidor fisico Celego
-> descarga
-> valida hash
-> descifra con llave privada
-> audita y conserva segun contrato
```

Datos permitidos en relay

- `deliveryId`, `deviceId`, `objectId`.
- Tipo de evidencia: acuse o cedula.
- Hash SHA-256 del blob cifrado.
- Tamano, estado tecnico, expiracion y timestamps.
- Metadata criptografica publica: algoritmo, IV, tag y llave temporal cifrada.

Datos prohibidos en relay

- Nombre del cliente.
- Cedula completa en texto.
- Direccion, telefono o tarjeta.
- Foto legible o base64 sin cifrar.
- Llave privada maestra o credenciales core.

3. Alta del VPS en Hostinger

Selección recomendada

Decision	Recomendación
Sistema operativo	Ubuntu 24.04 LTS o plantilla Docker de Hostinger
Region	La que apruebe BPD/legal; no asumir país por conveniencia
Hostname	`celego-relay-prod-01` o nombre equivalente
Tamaño inicial	Plan básico suficiente para relay; escalar por volumen real
Acceso	SSH keys, sin password root
Backups	Activar backup/snapshot antes de piloto

Pasos en hPanel

- Crear VPS o seleccionar el VPS dedicado al relay.
- Elegir Ubuntu 24.04 o Docker template si está disponible.
- Configurar hostname operativo, no genérico.
- Registrar la llave SSH pública del administrador.
- Activar firewall administrado o preparar grupo dedicado.
- Confirmar que backups/snapshots del plan están disponibles.

No guardar contraseñas, tokens, llaves privadas ni `.env` productivos en tickets o repositorios. Hostinger hPanel se usa para provisionar y recuperar, no como almacén de secretos Celego.

4. DNS, dominio y hostname

El dominio publico debe ser un subdominio dedicado. En ejemplos se usa `relay.celego.example`; en produccion debe reemplazarse por el dominio real aprobado.

Registros DNS

Tipo	Nombre	Valor
A	relay	IPv4 publica del VPS
AAAA	relay	IPv6 publica si se habilita
CAA	opcional	Permitir autoridad usada por Caddy/ACME si la politica lo exige

Validaciones

```
dig relay.celego.example A
dig relay.celego.example AAAA
curl -I http://relay.celego.example/health
curl -I https://relay.celego.example/health
```

Caddy necesita que el DNS resuelva al VPS y que los puertos 80/443 esten alcanzables para emitir y renovar certificados.

5. SSH keys y usuario sudo

Crear usuario operativo

```
sudo adduser celego
sudo usermod -s /bin/bash celego
sudo mkdir -p /home/celego/.ssh
sudo cp ~/.ssh/authorized_keys /home/celego/.ssh/authorized_keys
sudo chown -R celego:celego /home/celego/.ssh
sudo chmod 700 /home/celego/.ssh
sudo chmod 600 /home/celego/.ssh/authorized_keys
```

Deshabilitar password SSH

```
sudo nano /etc/ssh/sshd_config

PermitRootLogin prohibit-password
PasswordAuthentication no
PubkeyAuthentication yes

sudo systemctl reload ssh
```

Antes de cerrar la sesión root o aplicar cambios restrictivos, abrir una segunda terminal y validar que el usuario `celego` puede entrar por SSH y ejecutar `sudo -v`.

Rotacion de llaves

- Registrar propietario y fecha de cada llave pública.
- Eliminar llaves de personal que ya no administre el VPS.
- Rotar llave si se expuso en chat, ticket, repo o equipo no confiable.
- Mantener al menos dos administradores aprobados para continuidad.

6. Hardening Ubuntu

Actualizaciones base

```
sudo apt update
sudo apt -y upgrade
sudo apt -y install git curl ca-certificates ufw fail2ban
sudo apt -y autoremove
```

Actualizaciones automaticas

```
sudo apt -y install unattended-upgrades
sudo dpkg-reconfigure --priority=low unattended-upgrades
systemctl status unattended-upgrades --no-pager
```

Fail2ban minimo

```
sudo systemctl enable --now fail2ban
sudo fail2ban-client status
sudo fail2ban-client status sshd
```

Principios

- No instalar paneles extra si no son necesarios.
- No reutilizar el VPS para portal core, base de datos o archivos internos.
- No dejar scripts con tokens en el home del usuario.
- Documentar cada cambio operacional significativo.

7. Firewall Hostinger y UFW

Reglas publicas

Puerto	Origen	Destino	Motivo
80/tcp	Internet	Caddy	ACME HTTP challenge y redireccion
443/tcp	Internet	Caddy	API HTTPS del relay
22/tcp	IP administrativa	SSH	Administracion restringida
3900/tcp	Ninguno publico	Relay interno	Solo red Docker privada

UFW

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow from <IP_ADMIN>/32 to any port 22 proto tcp
sudo ufw allow 80/tcp
sudo ufw allow 443/tcp
sudo ufw enable
sudo ufw status verbose
```

Hostinger firewall es la primera capa. UFW es la segunda. Ambas reglas deben coincidir; si una abre SSH a internet y la otra lo cierra, queda una operacion confusa y dificil de auditar.

8. Docker y compose del relay

Instalacion si no se uso template Docker

```
curl -fsSL https://get.docker.com | sudo sh
sudo usermod -aG docker celego
newgrp docker
docker version
docker compose version
```

Servicios del compose

Servicio	Funcion	Exposicion
relay	Valida manifiestos y metadata tecnica	Solo red Docker interna
caddy	TLS, headers, proxy y logs HTTP	Puertos 80/443 del host
relay_metadata	Metadata temporal sin PII	Volumen Docker
caddy_data	Certificados ACME	Volumen Docker

Comandos base

```
docker compose --env-file infra/hostinger/.env \
-f infra/hostinger/docker-compose.relay.yml build

docker compose --env-file infra/hostinger/.env \
-f infra/hostinger/docker-compose.relay.yml up -d --force-recreate

docker compose --env-file infra/hostinger/.env \
-f infra/hostinger/docker-compose.relay.yml ps
```

9. Caddy con HTTPS automatico

Caddy se usa como estandar porque automatiza emision y renovacion HTTPS. Esto reduce operacion manual y evita scripts cron para certificados.

Caddyfile esperado

```
{
  email {$ACME_EMAIL}
  admin off
}

{$RELAY_DOMAIN} {
  encode zstd gzip
  request_body {
    max_size 18MB
  }
  header {
    Strict-Transport-Security "max-age=31536000; includeSubDomains"
    X-Content-Type-Options "nosniff"
    X-Frame-Options "DENY"
    Referrer-Policy "no-referrer"
    -Server
  }
  reverse_proxy relay:3900
}
```

Validaciones

- `curl -I https://<dominio>/health` responde con HTTPS valido.
- No hay certificado autofirmado.
- No se publica `http://<ip>:3900`.
- Logs Caddy no incluyen request bodies.

10. Variables y secretos

Plantilla `.env`

```
RELAY_DOMAIN=relay.celego.example  
ACME_EMAIL=ti@celego.example  
RELAY_PORT=3900  
RELAY_METADATA_FILE=/data/metadata.json  
COMPOSE_PROJECT_NAME=celego-relay
```

Reglas

- El `.env` real vive en el VPS y no se commitea.
- El relay no recibe `DATABASE\_URL` del core.
- El relay no recibe `NEXTAUTH\_SECRET` ni secretos del portal.
- La llave privada maestra no se copia al VPS.
- Si se agregan tokens de despliegue, deben rotarse y documentarse.

Si una variable no es necesaria para transportar blobs cifrados, no debe existir en el entorno del relay. Menos secretos significa menos radio de explosión si el VPS se compromete.

11. Despliegue desde Git

Clonar repo

```
sudo mkdir -p /opt/celego
sudo chown celego:celego /opt/celego
cd /opt/celego
git clone <REPO_URL> .
git checkout codex/evidencias-seguras-roadmap
cp infra/hostinger/.env.example infra/hostinger/.env
nano infra/hostinger/.env
```

Actualizar

```
cd /opt/celego
git fetch origin
git checkout codex/evidencias-seguras-roadmap
git pull --ff-only
docker compose --env-file infra/hostinger/.env \
  -f infra/hostinger/docker-compose.relay.yml up -d --build --force-recreate
```

Estrategia

- Usar `--ff-only` para evitar merges manuales en el VPS.
- Etiquetar commits estables antes de produccion.
- No editar codigo directamente en el VPS.
- Conservar runbook y salida de validacion por despliegue.

12. Pruebas de validacion

Healthcheck

```
curl -sS https://relay.celego.example/health
```

Payload con PII debe fallar

```
curl -sS -X POST https://relay.celego.example/evidence \
-H 'Content-Type: application/json' \
-d '{"nombre":"Cliente Prueba","cedula":"00112345678"}'
```

Respuesta esperada

```
{
  "error": "relay_payload_contains_pii",
  "path": "nombre",
  "reason": "field_name_contains_sensitive_label"
}
```

Pruebas de repo antes de liberar

```
npm run test
npm run lint
npm run build
docker compose build
docker compose up -d --force-recreate
docker compose ps
```

13. Backups y snapshots

El relay no es repositorio historico, pero si requiere capacidad de recuperar configuracion, certificados y metadata temporal no vencida.

Politica sugerida

Elemento	Retencion sugerida	Uso
Snapshot pre-deploy	7 a 14 dias	Rollback rapido
Backup Hostinger	Segun plan	Recuperacion operacional
relay_metadata	24 a 72 horas	Sincronizacion temporal
caddy_data	Vida del dominio	Certificados ACME
Logs	30 a 90 dias sin PII	Diagnostico y auditoria tecnica

Prueba trimestral

- Restaurar snapshot en ventana controlada o VPS temporal.
- Levantar stack con compose.
- Validar healthcheck HTTPS.
- Confirmar que metadata no contiene PII.
- Documentar resultado y destruir entorno temporal.

14. Monitoreo y logs

Indicadores minimos

Indicador	Alerta
`/health` no responde	Incidente alto si dura mas de ventana operativa
Errores 5xx	Revisar relay, Caddy y disco
Errores anti-PII	Revisar app movil o intento invalido
Hash mismatch	Investigar manipulacion o bug de cliente
Volumen metadata crece	Revisar limpieza y descargas pendientes
SSH fallidos repetidos	Validar Fail2ban/firewall

Comandos

```
docker compose --env-file infra/hostinger/.env \
  -f infra/hostinger/docker-compose.relay.yml ps

docker logs --tail=200 celego-relay
docker logs --tail=200 celego-relay-caddy
df -h
sudo fail2ban-client status sshd
```


15. Rollback

Rollback por código

```
cd /opt/celego
git checkout <commit-estable>
docker compose --env-file infra/hostinger/.env \
  -f infra/hostinger/docker-compose.relay.yml up -d --build --force-recreate
curl -sS https://relay.celego.example/health
```

Rollback por infraestructura

- Si Caddy falla por certificados, revisar DNS y puertos 80/443.
- Si relay falla por build, volver al commit estable.
- Si VPS queda inconsistente, restaurar snapshot Hostinger.
- Si se sospecha compromiso, no restaurar volumen sin revisión de Seguridad.

Rollback no debe reintroducir versiones que acepten PII o fotos legibles en relay. La seguridad del contrato tiene prioridad sobre recuperar velocidad.

16. Incidentes

VPS comprometido

- Cerrar SSH a todo origen salvo IP de emergencia.
- Detener stack si existe actividad sospechosa.
- Preservar logs y hashes de archivos modificados.
- Rotar llaves SSH y tokens de despliegue.
- Reconstruir desde snapshot limpio o VPS nuevo.
- Confirmar que no habia PII ni llave privada en el relay.

PII detectada en relay

- Confirmar si el payload fue rechazado antes de persistir.
- Si se persistio, aislar metadata y notificar a Seguridad.
- Eliminar con aprobacion y registrar evidencia tecnica.
- Crear prueba automatizada para bloquear recurrencia.

Dispositivo perdido

- Marcar dispositivo `LOST` o `REVOKED`.
- Revocar token/certificado.
- Ejecutar bloqueo o borrado remoto por MDM.
- Identificar rutas y evidencias pendientes.
- Escalar a BPD/legal segun protocolo aprobado.

17. Checklist final de produccion

Categoria	Evidencia requerida	Estado
DNS	Subdominio resuelve al VPS	Pendiente
TLS	Certificado valido en HTTPS	Pendiente
Firewall	Hostinger y UFW documentados	Pendiente
SSH	Password deshabilitado, IP restringida	Pendiente
Relay	`/health` responde 200	Pendiente
Anti-PII	Payload sensible rechazado	Pendiente
Backups	Snapshot y backup activos	Pendiente
Restore	Prueba de restauracion registrada	Pendiente
Legal	Region y retencion aprobadas	Pendiente
Operacion	Contactos e incidente definidos	Pendiente

Este checklist debe anexarse al acta de salida. Si un punto queda en `Pendiente`, el equipo debe decidir si es bloqueante o si el piloto sera solo tecnico sin evidencias reales.

18. Anexo A - Comandos rapidos

Operar stack

```
cd /opt/celego
docker compose --env-file infra/hostinger/.env \
  -f infra/hostinger/docker-compose.relay.yml ps
docker compose --env-file infra/hostinger/.env \
  -f infra/hostinger/docker-compose.relay.yml logs --tail=200
docker compose --env-file infra/hostinger/.env \
  -f infra/hostinger/docker-compose.relay.yml restart relay
```

Inspeccionar volumen

```
docker volume ls | grep relay
docker exec celego-relay node -e "console.log(process.env.RELAY_METADATA_FILE)"
docker exec celego-relay ls -lah /data
```

Red y puertos

```
sudo ss -tulpn
sudo ufw status verbose
curl -sS https://relay.celego.example/health
```

19. Anexo B - Fuentes

- Hostinger VPS dashboard:
<https://www.hostinger.com/support/5726606-how-to-use-the-vps-dashboard-in-hostinger/>
- Hostinger SSH keys: <https://www.hostinger.com/tutorials/how-to-set-up-ssh-keys>
- Hostinger VPS firewall:
<https://www.hostinger.com/support/8172641-how-to-use-a-managed-vps-firewall-at-hostinger/>
- Hostinger Docker on Ubuntu/template: <https://www.hostinger.com/tutorials/how-to-install-docker-on-ubuntu>
- Hostinger VPS backups/snapshots: <https://www.hostinger.com/vps-hosting>
- Caddy Automatic HTTPS: <https://caddyserver.com/docs/automatic-https>
- Ubuntu UFW: <https://ubuntu.com/server/docs/how-to/security/firewalls/>
- Ubuntu Fail2ban community docs: <https://help.ubuntu.com/community/Fail2ban>

Las fuentes deben revisarse nuevamente antes de ejecutar produccion, porque Hostinger puede cambiar pantallas, nombres de menus o funciones incluidas por plan.